

Informática Forense

0. Introducción

PRESENTADO POR:
David Santo Orcero

ENTIDAD
Perito judicial

MÓDULO
Avanzado

SOBRE EL PROFESOR



Sobre el profesor. . .

David Santo Orcero

- Doctor e Ingeniero en Informática
- Ingeniero en Organización Industrial
- Perito judicial y auditor de seguridad desde hace más de 20 años
- Más de 25 años de experiencia profesional
- Profesor asociado a tiempo parcial en la Universidad de Málaga; con más de 4000 horas de docencia impartidas en universidades de varios países.



Sobre el profesor. . .

- Mas de 25 cursos de informática forense, peritajes informáticos, y herramientas de informática forense en universidades de varios países.
- Decano del Colegio Profesional de Ingeniería en Informática de Andalucía desde el año 2018 hasta hace un mes (ahora vocal)
- Miembro del comité de expertos que asesora a la Junta de Andalucía en la Estrategia Andaluza de Ciberseguridad 2022-2025 y miembro del consejo asesor de la Agencia Digital Andaluza.



Sobre el profesor. . .

- Miembro del cuerpo de visadores de informes periciales del Colegio Profesional de Ingeniería en Informática de Andalucía.
- Coordinador de los grupos de trabajo del Consejo de Colegios de Ingeniería en Informática *Seguridad y Defensa y Periciales e Informática Forense* entre el 2018 y el 2022.
- Vocal del Consejo de Colegios de Ingeniería en Informática entre el año 2018 y el 2023.



Sobre el profesor. . .

- Miembro desde el año 2014 del comité técnico de la Asociación Española de Normalización UNE AEN/CTN 197 *Informes de actuaciones periciales* y de sus grupos de trabajo GT1 de *Informes periciales*.
- Coautor de la norma UNE 197010:2015 *Criterios generales para la elaboración de informes y dictámenes periciales sobre Tecnologías de la Información y las Comunicaciones (TIC)* y de la norma UNE 197001:2019 *Criterios generales para la elaboración de informes periciales*.



Sobre el profesor...

- Miembro desde el año 2018 del comité técnico de UNE CTN 320 *Ciberseguridad y protección de datos personales*; responsable del desarrollo de estándares para la ciberseguridad. Miembro de sus grupos de trabajo SC3 *Evaluación, pruebas y especificaciones de seguridad*, y miembro del grupo de trabajo SC4 *Controles y servicios de seguridad*, que se encarga de la familia de normas técnicas de seguridad informática ISO 27000, así como del grupo de trabajo responsable de la norma UNE-EN ISO/IEC 27037 *Directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas*.



Sobre el profesor. . .

- Miembro desde el año 2019 del comité internacional ISO/IEC JTC 1/SC 27 *Information security, cybersecurity and privacy protection* en calidad de experto, participante del WG 4, responsable, entre otros estándares, de las normas internacionales ISO/IEC 27037 *Guidelines for identification, collection, acquisition and preservation of digital evidence*, ISO/IEC 27041 *Guidance on assuring suitability and adequacy of incident investigative method*, ISO/IEC 27042 *Guidelines for the analysis and interpretation of digital evidence*, y ISO/IEC 27043 *Incident investigation principles and processes*.



Sobre el profesor. . .

- Auditor de Sistemas de Gestión de Seguridad de la Información ISO 27001 certificado por Bureau Veritas.
- Autor de cuatro libros técnicos de informática. Más de 60 conferencias impartidas en varios países; 7 convenios OTRI como investigador principal, y más de 75 proyectos fin de carrera, trabajos fin de grado y trabajos fin de master dirigidos.

David Santo Orcero - Doctor Ingeniero en Informática

Perito forense colegiado en Informática y en Nuevas Tecnologías TIC



Sobre el profesor. . .

Resumiendo:

Aprovechad que me dedico a esto y cosedme a preguntas.

DE QUÉ NO VA EL CURSO





Qué no vamos a tocar en el curso

- Qué es un perito. Responsabilidades del perito.
- Aspectos legales de la informática forense
- Redacción de informes periciales.
- Ratificación de informes periciales en juzgado.
- Relación con encargantes de informe, letrados y tribunales.
- Contratación y estimación de precios de informes periciales.



Qué no vamos a tocar en el curso

- Informática forense policial.
- Análisis de integridad de pruebas (audios, vídeos, fotografías, conversaciones de WhatsApp, correos electrónicos)
- Artefactos forenses en detalle (Windows, Linux, MacOS X, Android, iOS).
- Extracciones de imágenes forenses de dispositivos móviles.
- Extracciones forenses complejas (datacenters, bitlocker)



Qué no vamos a tocar en el curso

- DFIR
- OSInt
- Pentesting
- Hacking
- Espionaje y contraespionaje



Qué vamos a ver en este curso

- Lo que legalmente podemos hacer.
- DEFR en mercantil y laboral.
- Con mucho cuidado, DEFR en delitos privados, normalmente por la parte actora antes de la judicialización.
- AF dentro del ámbito que se puede legalmente realizar por un perito.

(Las siglas las vamos a ver ahora)



Qué vamos a ver en este curso

- 9:00-10:00 Conceptos y metodologías
- 10:00-11:00 DEFR (primera intervención)
- 11:00-11:30 Descanso
- 11:30-12:30 Práctica de primera intervención: volcado forense de disco duro con Caine y comprobación de hashes
- 12:30-13:00 AF (análisis forense)
- 13:00-13:30 Práctica de análisis forense: análisis forense de una imagen forense de Windows mediante Autopsy
- Si sobra tiempo aprenderemos a usar Volatility



Avisos (1/2)

- **No va a dar tiempo a todo:** Cada uno de los puntos anteriores los imparto habitualmente en cursos básicos introductorios de extensión de 25 horas, o en cursos de 300 horas. No puedo dar 300 horas en 45 minutos.
- **Es imposible dar lo mínimo suficiente en tres horas y media:** en el material hay muchas cosas que no voy a explicar y he puesto en la presentación solo para que las tengáis como referencia o las leáis porque son importantes.



Avisos (2/2)

- **Hay mucho que no cuento:** Solo en artefactos forenses, hay libros enteros para cubrir los cientos de artefactos forenses existentes.
- **Mentalizaos que este es el punto de entrada a una vida de estudio:** Según cambian las tecnologías, hay que estar constantemente estudiando para estar al día, y también hacer “arqueología tecnológica” porque puede que tengas que analizar tecnologías antediluvianas.

CONCEPTOS PREVIOS



Cadena de custodia

Definición por norma UNE 197010:2015

- *“Procedimiento de trazabilidad controlada que se aplica a las evidencias digitales, a lo largo de su vida útil.”*
- *“La cadena de custodia tiene como fin preservar la integridad y autenticidad de las mismas, asegurando en todo este proceso que la información relevante no sea alterada.”*



Cadena de custodia

Definición común

Procedimiento de control que se emplea para los indicios materiales afines al delito, desde su ubicación, hasta que son valorados por los diferentes encargados de su análisis, normalmente miembros de las FCSE o peritos; y que tiene como finalidad no viciar el manejo que de ellos se haga, y así evitar la contaminación, alteración, daños, reemplazos, contaminación o destrucción.



Cadena de custodia

Definición común

La cadena de custodia no deja de ser un mecanismo cuyo uso finalista es preservar la prueba de tal forma que todos los intervinientes del proceso tengan asegurada la posibilidad de un acceso inalterado a la evidencia original.



Cadena de custodia

Porqué es importante

- **Elemento clave en la contrastabilidad de las pruebas por las partes y el principio de contradicción**
- **Elemento clave para asegurar el principio de igualdad de armas en un proceso judicial frente a material evidenciario de origen digital.**



Evidencia digital

Particularidades de la evidencia digital

- Puede ser creada de la nada.
- Puede ser alterada sin dejar rastro.
- Requiere de conocimientos técnicos especializados para valorar su fiabilidad.



Evidencia digital

Afortunadamente...

- Existen medios formales que permiten asegurar con total seguridad que no ha sido alterada.
- Gestionada de la forma adecuada, puede ser replicada de forma exacta sin pérdida de calidad.
- Una vez extraída de forma apropiada, por su replicabilidad permite –gestionada de la forma adecuada– que las pruebas periciales sean completamente replicables y no destructivas.
- ...



Evidencia digital

Afortunadamente...

- ...
- La fiabilidad de la prueba digital depende de la metodología que se haya seguido para su adquisición.
- La evidencia digital con la metodología adecuada tiene un nivel de contrastabilidad del que otras pruebas pueden carecer.



Perfiles involucrados

- Dos perfiles: DEFR y DES.
- Comunes en NIST, NIJ y normas familia UNE 27000.



Perfiles involucrados

DEFR

- Responsable de la primera intervención.
- Corresponde con el “First Responder”.
- Persona con autoridad, entrenamiento y preparación para ser el primero que actúa en una escena dónde se cometió un incidente; actuando mediante la recogida y adquisición de la evidencia digital. Se le responsabiliza de su manejo.



Perfiles involucrados

DEFR

- En el sistema español, en delitos públicos corresponde a las FCSE.
- En penal, solo podremos hacer DEFR delitos privados y semipúblicos (con limitaciones)
- Cuidado con invalidar las pruebas por “pasarte de DFIR”.

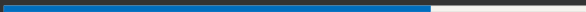


Perfiles involucrados

AF/DES

- Analista forense/Digital Evidence Specialist.
- Persona con conocimientos especializados, destrezas y habilidades para el manejo de cuestiones técnicas.
- Ojo: **Las FCSE hacen periciales, pero no son peritos: no tienen los requisitos ni las limitaciones de los peritos (tienen otros)**

LA FIRMA HASH





La firma hash

Qué es

- Fórmula matemática que, aplicada sobre la evidencia digital, da un valor que sufre grandes cambios ante pequeños cambios de la evidencia.
- Asegura de forma matemática la inalteración de la prueba digital.
- La idea clave detrás de la firma hash es que es unidireccional/no reversible.
- Definida, entre otras, en la ISO/IEC 27037.



La firma hash

Cómo se usa

- Se entrega a las partes, así ambas partes pueden siempre verificar la integridad de la prueba con total fiabilidad, independientemente de quién sea el custodio.
- Si la firma hash se mantiene constante, es imposible que la prueba se haya alterado. Independientemente de cómo se haya transmitido o almacenado.
- Si la firma hash ha cambiado, es seguro que la prueba se ha alterado. Independientemente de cómo se haya transmitido o almacenado.



La firma hash

Tipos de firmas hash

- ☐ CRC (nunca en forense)
- ☐ MD5
- ☐ SHA-0
- ☐ SHA-1
- ☐ SHA-2
- ☐ SHA-3



La firma hash

CRC

- No es realmente una firma hash, pero se incluye por razones de completitud.
- Es un mecanismo para validar corrupción de datos.
- Es trivialmente fácil encontrar una colisión.
- No se debe utilizar como firma hash bajo ningún concepto: no cubre las mínimas propiedades de una firma hash.
- Solo se utiliza para validar en las transmisiones que el ruido inintencionado no ha corrompido una secuencia de datos.



La firma hash

MD5

- Es el más veterano.
- Se considera criptográficamente vulnerable desde 1996, y desde ese año la comunidad criptográfica solo lo recomienda para verificar la integridad de datos contra corrupción inintencional de estos en copia o en transmisión (validar por un golpe de vista)
- El cálculo de colisiones es costoso, pero viable.
- No vale para demostrar la conservación de la cadena de custodia.



La firma hash

SHA-0

- Diseñado por la NSA.
- Se considera criptográficamente vulnerable desde 2004.
- El hecho de que se encontraran vulnerabilidades hicieron que se criticara también al SHA-1, al ser similar.



La firma hash

SHA-1

- Diseñado por la NSA.
- Se considera criptográficamente vulnerable desde 2005.
- Desde 2010 se recomienda que se abandone su uso.
- El primer ataque por colisión de demostró en el 2017.



La firma hash

SHA-2

- Diseñado por la NSA, y publicado por el FIPS PUB 180-2 del NIST en 2001.
- Es el más popular desde hace años, en su versión de SHA-512.
- Aunque comparte aspectos con el SHA-1, las diferencias son suficientes como para que el tipo de ataques que admite SHA-0 y SHA-1 no lo admita SHA-2.
- Actualmente se considera segura, y es la que yo personalmente utilizo.



La firma hash

SHA-3

- Diseñado por un concurso público en el que compitieron distintos algoritmos para funciones hash.
- No guarda ninguna relación con SHA-2, ni con SHA-1, ni con SHA-0.
- Se publicó en el 2012, y en el 2015 pasó a ser el estándar hash de NIST junto con SHA-2.



La firma hash

Fiabilidad - los que no debemos usar

- Podemos la firma hash con MD5 anterior a 2013, cualquier firma hash con SHA-0 anterior a 2008, y cualquier firma hash con SHA-1 anterior a 2017.
- En principio, podemos suponer seguras las firmas hash con MD5 de archivos pequeños, y de SHA-0 o SHA-1 de archivos medianos.



La firma hash

Fiabilidad - los que debemos usar

- En la fecha en la que se escribe esta presentación, se consideran seguros el SHA-2 en sus variantes de SHA-512/224 y SHA-512/256, así como todas las variantes de SHA-3 –SHA3-224, SHA3-256, SHA3-384, SHA3-512, SHAKE128 y SHAKE256–.